Informe anexo consolidado de incidencias MS-User · ScoutConnect

Fecha de emisión: 28 de octubre de 2026

Período de detección: 20 al 28 de octubre de 2026

Cobertura: Revisión funcional y de seguridad del microservicio MS-User; incidencias identificadas entre API-U01 y API-U11.

Estado del corte: Revisión inicial finalizada; cuatro incidencias de seguridad pendientes de corrección y nuevas pruebas.

1. Resumen ejecutivo

Se consolidaron cuatro incidencias relacionadas con controles de autenticación y autorización del microservicio MS-User. Las operaciones observadas respondieron funcionalmente, pero determinadas rutas permitieron consultar o modificar recursos sin demostrar la identidad del solicitante. Los casos se mantienen abiertos hasta aplicar las correcciones y repetir las pruebas de regresión.

La fecha consignada en cada incidencia corresponde al día del hallazgo o ejecución registrado en la revisión, no a la fecha de creación del Plan Maestro (15-10-2026). En API-U06, la fecha procede del registro previo de revisión; para API-U09, U10 y U11 hay además capturas de Postman con nomenclatura fechada.

2. Registro cronológico

Incidencia	Fecha detectada	Prueba / componente	Hallazgo principal	Estado
SEG-U06-01	20-10-2026	API-U06 · Perfiles	Consulta de perfil sin autenticación.	Abierta
SEG-U09-01	22-10-2026	API-U09 · Mensajes	Consulta de mensajes sin autenticación.	Abierta
SEG-U10-01	28-10-2026	API-U10 · Mensajes	Cambio de estado y eliminación sin autenticación.	Abierta
SEG-U11-01	28-10-2026	API-U11 · Respuestas / adjuntos	Respuesta y descarga de adjunto sin autenticación.	Abierta

Severidad sugerida para priorización: ALTA (preliminar), sujeta a la evaluación de impacto y exposición del entorno. No se constató explotación fuera de la base de prueba.

3. Detalle de incidencias

3.1 SEG-U06-01 — Acceso a perfiles sin autenticación

Fecha del hallazgo: 20-10-2026

Rutas / escenario: API-U06 · /usuarios/perfil/{correo}

Resultado observado: En la revisión previa se observó una consulta GET de perfil que respondió HTTP 200 con Postman configurado sin autenticación, exponiendo información del perfil.

Riesgo: Una ruta de datos personales no debe confiar en el correo de la URL como comprobante de identidad. Existe riesgo de consulta de perfiles ajenos si no se exige autenticación y control de titularidad.

Código a revisar: SecurityConfig.java; controlador de usuarios/perfil y mecanismos de validación del titular del recurso.

Trazabilidad: Captura y registro original de API-U06: localizar/incorporar al expediente de evidencias; no se adjunta en este informe una imagen específica de esa prueba.

3.2 SEG-U09-01 — Consulta de mensajes sin autenticación

Fecha del hallazgo: 22-10-2026

Rutas / escenario: API-U09 · GET /mensajes/enviados/1

Resultado observado: La consulta de mensajes enviados respondió HTTP 200 con No Auth, entregando datos de mensajes del usuario indicado en la ruta. Las pruebas de creación y consulta formaron parte del escenario funcional de U09.

Riesgo: Posible divulgación de mensajes y metadatos mediante identificadores modificables por el cliente, sin vinculación con una identidad autenticada.

Código a revisar: SecurityConfig.java; MensajeController.java, especialmente listados de mensajes enviados/recibidos y validaciones de acceso.

Trazabilidad: Capturas del 22-10-2026: image(20261022-003816).png y image(20261022-004046).png; conservar además las capturas EVD-API-U09.

3.3 SEG-U10-01 — Modificación y eliminación de mensajes sin autenticación

Fecha del hallazgo: 28-10-2026

Rutas / escenario: API-U10 · PUT /mensajes/5/leer?usuarioId=2; DELETE /mensajes/5?usuarioId=2

Resultado observado: El PUT devolvió HTTP 200 y el mensaje ID 5 pasó de NO_LEIDO a LEIDO. El DELETE devolvió HTTP 200; después el ID 5 dejó de aparecer en la lista consultada. Las solicitudes se configuraron en No Auth.

Riesgo: Los permisos se comparan con usuarioId proporcionado por el cliente. Cambiar el estado o solicitar la eliminación sin identidad autenticada genera riesgo de suplantación y alteración o pérdida de mensajes.

Código a revisar: SecurityConfig.java; MensajeController.java (marcarLeido y eliminarMensaje); repositorio/entidad Mensaje y política de borrado/cascadas de adjuntos.

Trazabilidad: Capturas del 28-10-2026: image(20261028-232044).png, image(20261028-232248).png, image(20261028-232523).png e image(20261028-232801).png.

3.4 SEG-U11-01 — Respuestas y descarga de adjuntos sin autenticación

Fecha del hallazgo: 28-10-2026

Rutas / escenario: API-U11 · POST /mensajes/6/respuesta; GET /mensajes/adjuntos/2

Resultado observado: POST /mensajes/6/respuesta devolvió HTTP 201 y creó el mensaje ID 7 (remitente 2, destinatario 1). GET /mensajes/adjuntos/2?usuarioId=2 devolvió HTTP 200 y descargó la imagen; con usuarioId=3 devolvió HTTP 403. Se confirmó No Auth, sin cookies de sesión ni encabezados de autorización.

Riesgo: El 403 prueba una comparación de identificadores, pero no valida quién formula la petición. Se pudo descargar un adjunto y responder un mensaje usando valores de identidad proporcionados en la solicitud sin autenticación.

Código a revisar: SecurityConfig.java; MensajeController.java (respuesta y descarga de adjuntos); relación adjunto-mensaje y control de titularidad de archivos.

Trazabilidad: Capturas del 28-10-2026: image(20261028-235455).png (POST 201), image(20261028-235658).png (GET 200), image(20261028-235931).png (GET 403).

4. Causa transversal y alcance

En la revisión de código precedente se identificó una configuración de seguridad de tipo .anyRequest().permitAll(), además de la excepción .requestMatchers("/usuarios/**").permitAll(). Esto permite solicitudes a rutas privadas sin exigir autenticación. La ausencia de validación de identidad real se agrava cuando los controladores confían en identificadores como usuarioId o correo enviados desde el cliente.

La conclusión anterior corresponde a la versión revisada en este ciclo y debe volver a verificarse si el equipo ya modificó el código. El HTTP 403 observado en U11 no contradice el hallazgo: restringe un identificador, pero no demuestra que el solicitante sea su titular.

5. Acciones correctivas prioritarias

1. Implementar un mecanismo de autenticación de servidor (por ejemplo JWT validado o sesión gestionada por Spring Security); definir claramente endpoints públicos y privados.

2. Sustituir las reglas generales permitAll por reglas restrictivas y revisar expresamente todas las rutas de usuarios y mensajes.

3. Obtener la identidad desde el contexto autenticado; no autorizar operaciones usando solo usuarioId, correo o IDs enviados por el cliente.

4. Comprobar autorización por recurso para perfiles, mensajes, respuestas, archivos y acciones de modificación/eliminación.

5. Definir la política funcional de eliminación (física frente a ocultación por participante) y revisar efectos de borrado en adjuntos y relaciones.

6. Actualizar el frontend para enviar credenciales en forma segura y manejar 401/403; registrar eventos de acceso y denegación sin exponer datos sensibles.

7. Repetir API-U06, U09, U10 y U11 con pruebas negativas (sin autenticación, usuario ajeno, manipulación de identificador) y positivas (titular autenticado).

6. Criterios de cierre y regresión

Escenario	Resultado esperado después de la corrección
GET perfil o mensajes sin autenticación	401 Unauthorized; sin datos sensibles.
POST respuesta / PUT estado / DELETE mensaje sin autenticación	401 Unauthorized; ningún cambio persistente.
GET adjunto sin autenticación	401 Unauthorized; sin contenido binario.
Usuario autenticado sin permiso para el recurso	403 Forbidden (o 404 según diseño anti-enumeración).
Titular autenticado / autorizado	200 o 201 según operación; recurso correcto.
PUT/DELETE rechazado	Estado y contenido inalterados en posterior GET.

7. Estado al 28 de octubre de 2026

Las incidencias SEG-U06-01, SEG-U09-01, SEG-U10-01 y SEG-U11-01 permanecen ABIERTAS. El funcionamiento positivo de U09–U11 fue observado, pero su cierre de seguridad es NO APROBADO. No se considera que las fallas estén corregidas ni que el microservicio sea apto para desplegar datos reales sin repetir las validaciones de control de acceso.

Limitación documental: este consolidado reúne únicamente los hallazgos y evidencias identificados en la revisión disponible. No atribuye incidencias a API-U01–U05, U07 ni U08 sin resultados que las sustenten, y no asigna a esas pruebas un estado global no verificado.